

1. 제정이유

최근 자동차의 핵심 기술이 하드웨어에서 소프트웨어 기반으로 급속히 전환되고 통신을 활용한 외부와의 연결 기능이 확산됨에 따라, 해킹 등의 사이버공격·위협으로부터 자동차의 사이버보안을 확보하고 자동차 안전에 영향을 줄 수 있는 소프트웨어 업데이트를 관리할 필요성이 증대되고 있음.

이에, 자동차 사이버보안 확보를 위한 「자동차관리법」 제30조의9(자동차 사이버보안 관리체계 인증 등) 및 제30조의10(자동차 사이버보안 관리체계 관련 자료의 제출 요구)에 따라 자동차 사이버보안 관리체계 인증제도 신설에 따른 인증신청 시 사전 준비서류, 인증심사 절차, 인증서 발급·재발급 절차 및 인증 사후관리를 위한 자료 제출 등 법률에서 위임된 사항과 그 시행에 필요한 사항을 정하려는 것임.

2. 주요내용

- 가. 자동차 사이버보안 관리체계 인증 신청 시 사전 준비사항과 인증 신청 절차 신설(안 제3조 및 제4조)
- 나. 자동차 사이버보안 관리체계 인증기준 규정(안 제6조 및 별표 1)
- 다. 자동차 사이버보안 관리체계 인증심사의 방법, 심사 중단·재개 및 이의신청할 수 있는 경우 규정(안 제7조부터 제9조까지)
- 라. 인증서 발급, 재발급 및 반환 등 관리규정 마련(안 제10조 및 제11조)
- 마. 자동차 사이버보안 관리체계 인증 관련 운영 자료의 제출 절차 신

설(안 제12조)

3. 참고사항

가. 관계법령 : 자동차관리법 및 같은 법 시행규칙

나. 예산조치 : 별도조치 필요 없음

다. 합 의 : 0부, 0실과 합의되었음

라. 기 타 : 신·구조문 대비표

자동차 사이버보안 관리체계 인증 등에 관한 고시

제1장 총 칙

제1조(목적) 이 고시는 「자동차관리법」 제30조의9부터 제30조의12까지 및 같은 법 시행규칙 제40조의26부터 제40조의30까지에 따라 자동차 사이버보안 관리체계 인증에 관하여 위임된 사항, 「자동차 및 자동차부품의 성능과 기준에 관한 규칙」(이하 “자동차규칙”이라 한다) 제18조의4에 따라 자동차 사이버공격·위협 및 보안조치 등에 관하여 위임된 사항 및 그 밖에 자동차 사이버보안 관리체계 인증에 관하여 필요한 세부 사항을 정하는 것을 목적으로 한다.

제2조(정의) 이 고시에서 사용하는 용어의 뜻은 다음 각 호와 같다.

1. “자동차 사이버보안 관리체계 인증”이란 「자동차관리법」(이하 “법”이라 한다) 제30조의9제1항에 따라 자동차 사이버보안 관리체계 인증을 취득하려는 자(이하 “신청인”이라 한다)의 자동차 사이버보안을 위한 일련의 조치와 활동이 인증기준에 적합함을 증명하는 것을 말한다.
2. “인증심사”란 신청인이 수립한 자동차 사이버보안 관리체계가 인증기준에 적합한지의 여부를 서류심사 및 현장심사의 방법으로 확인하는 것을 말한다.

3. “서류심사”란 신청인이 제출한 자동차 사이버보안 관리체계 관련 서류가 인증기준에 적합한지에 대하여 서면 및 대면 질의 등의 방법으로 실시하는 인증심사를 말한다.
4. “현장심사”란 서류심사의 결과가 현장과 일치하는지의 여부 및 서류심사로 심사하기 곤란한 사항에 대하여 면담 및 현장 확인 등의 방법으로 실시하는 인증심사를 말한다.

제2장 인증심사의 신청 및 수수료 납부

제3조(사전 준비사항) ① 신청인은 인증심사를 위하여 다음 각 호의 사항을 준비해야 한다.

1. 인증심사를 위한 문서 및 증거자료
 2. 인증심사 수행에 필요한 장소·시설·장비 등
 3. 그 밖에 인증심사를 수행하기 위하여 성능시험대행자가 요구하는 사항
- ② 성능시험대행자는 심사 일정 등을 신청인과 사전 협의하여야 한다.
- ③ 성능시험대행자는 제1항에 따른 사전 준비사항에 대하여 보완이 필요하다고 인정하면 신청인에게 보완을 요구할 수 있다.

제4조(인증 신청 등) ① 신청인은 자동차 사이버보안 관리체계 인증 또는 변경인증을 신청하는 경우 「자동차관리법 시행규칙」(이하 “규칙”이라 한다) 제40조의27제1항에 따른 인증 신청서에 다음 각 호의 서류를 첨부하여 성능시험대행자에게 제출하여야 한다.

1. 자동차 사이버보안 관리체계 명세서

2. 제6조에 따른 자동차 사이버보안 관리체계 인증기준에 적합함을 증명하는 서류

② 인증을 받은 자가 법 제30조의9제2항 단서 및 규칙 제40조의28에 따라 다음 각 호 중 어느 하나에 해당하는 사항을 변경하려는 경우 별지 제1호서식에 따른 인증서 변경 신고서에 변경내용을 증명하는 서류를 첨부하여 성능시험대행자에게 제출하여야 한다.

1. 인증을 받은 자의 상호

2. 자동차 사이버보안 관리체계 관련 조직

3. 최초 제작자의 상호

③ 인증을 받은 자로서 인증의 갱신을 원하는 자는 인증서 유효기간이 만료되기 5개월 전까지 제1항에 따른 인증심사를 신청하여야 한다.

제5조(수수료의 납부) 신청인은 성능시험대행자가 정하는 수수료를 성능시험대행자가 지정하는 날까지 성능시험대행자에 납부하여야 한다.

제3장 인증심사의 기준과 방법

제6조(인증기준) 법 제30조의9제3항에 따른 자동차 사이버보안 관리체계 인증기준은 별표 1과 같다.

제7조(인증심사 방법 및 보완조치) ① 인증심사는 서류심사 및 현장심사로 구분하여 실시한다.

② 제1항에도 불구하고 「재난 및 안전관리 기본법」 제3조제1호에 따

른 재난 등 국토교통부장관이 인정하는 부득이한 경우에는 현장심사를 원격심사로 대체할 수 있다.

- ③ 성능시험대행자는 인증심사 결과 인증기준에 부적합할 경우 신청인에게 100일 이내의 기간을 정하여 보완하도록 요구할 수 있다.

제8조(심사중단) ① 성능시험대행자는 다음 각 호의 사유가 발생한 경우에는 인증심사를 중단할 수 있다.

1. 신청인이 고의로 인증심사의 실시를 지연 또는 방해하거나 신청인의 귀책사유로 인하여 인증심사를 계속 진행하기가 곤란하다고 인정되는 경우
2. 신청인이 제출한 관련 자료 등을 검토한 결과 인증심사를 받을 준비가 되었다고 볼 수 없는 경우
3. 제7조제3항에 따른 보완조치를 기한 내에 완료하지 않은 경우
4. 「재난 및 안전관리 기본법」 제3조제1호에 따른 재난의 발생 또는 경영환경 변화 등으로 인하여 인증심사 진행이 불가능하다고 판단되는 경우

② 성능시험대행자는 제1항에 따라 인증심사를 중단하는 때에는 그 사유를 신청인에 서면으로 통보하여야 한다.

③ 성능시험대행자는 제1항의 인증심사 중단 사유 해소 여부 또는 제9조제2항에 따른 이의신청 처리결과에 따라 인증심사를 재개하거나 종결할 수 있다.

제9조(이의신청) ① 신청인은 제7조제3항의 보완조치 요구, 제8조의 인증심사 중단 등 인증심사와 관련된 조치에 대해 이의가 있는 때에는

그 조치가 있는 날로부터 15일 이내에 별지 제2호 서식의 이의신청서를 성능시험대행자에 제출할 수 있다.

② 제1항에 따른 이의신청이 있는 경우 성능시험대행자는 신청인에게 이의신청에 대한 처리결과를 30일 이내에 통지하여야 한다.

제4장 인증서 발급 및 관리

제10조(인증서의 발급 등) ① 성능시험대행자는 규칙 제40조의2제2항에 따른 인증심사 결과 인증적합으로 판정된 경우 신청인에게 규칙 제40조의2제3항에 따라 자동차 사이버보안 관리체계 인증서를 발급하여야 한다.

② 인증서 발급 시 인증번호는 별표 2의 자동차 사이버보안 관리체계 인증번호 부여기준을 따른다.

③ 제1항에 따른 인증서의 유효기간은 인증서 발급일(단, 제4항에 의한 인증서 재발급의 경우 최초 또는 갱신 발급일)로부터 3년으로 한다.

④ 인증을 받은 자는 법 제30조의9제2항에 따른 변경신고, 인증서의 분실 등으로 인해 인증서를 재발급 받고자 할 경우 별지 제3호서식의 인증서 재발급 신청서를 성능시험대행자에 제출하여야 한다.

⑤ 인증을 받은 자가 제4조제3항에 따라 인증서 유효기간이 만료되기 5개월 전까지 인증심사를 신청한 경우 인증의 갱신 신청에 대한 결과를 통지받을 때까지는 그 인증이 계속 유효한 것으로 본다.

⑥ 인증을 받은 자가 국토교통부장관으로부터 법 제30조의11에 따른

자동차 사이버보안 관리체계 인증취소의 통지를 받은 경우 성능시험 대행자에게 인증서를 반환하여야 한다.

제11조(인증서 관리) 성능시험대행자는 발급한 인증서의 인증번호, 발급 일, 유효기간 등을 관리하여야 한다.

제12조(자동차 사이버보안 관리체계 관련 운영 자료의 제출 등) ① 성능 시험대행자는 자동차 사이버보안 관리체계의 사후관리, 사이버 공격 위협 발생 등 자동차 사이버보안 관리체계 점검·관리를 위해 필요한 경우 규칙 제40조의29에 따라 다음 각 호의 자료의 제출을 요구할 수 있다.

1. 수집된 자동차 사이버공격·위협에 대한 정보 및 대응 현황
2. 제1호에 따라 수집된 정보 중 새로운 정보에 대하여 기존 자동차 사이버보안 조치가 여전히 유효한지의 여부
3. 기존 자동차 사이버보안 조치가 유효하지 않은 경우 추가 보완조치의 시행 여부
4. 그 밖에 자동차 사이버보안 관리체계 점검·관리를 위해 성능시험대행자가 요청하는 자료

② 성능시험대행자는 제1항에 따라 제출된 자료를 확인하여 법 제30조의11제1항 각호에 해당하는 인증취소 사유가 있는 것으로 판단되는 경우 이를 국토교통부장관에게 보고하여야 한다.

제5장 자동차 사이버공격·위협 등

제13조(자동차 사이버공격·위협) 자동차규칙 제18조의4제2호다목의 “국토교통부장관이 정하여 고시하는 자동차 사이버공격·위협”이란 별표3과 같다.

제14조(자동차 사이버공격·위협에 대한 보안조치) 자동차규칙 제18조의4제4호의 “국토교통부장관이 정하여 고시하는 자동차 사이버공격·위협에 대한 보안조치”란 별표4와 같다.

제6장 인증업무 일반 등

제15조(비밀유지 등) ① 인증심사 업무에 종사하는 자 또는 종사했던 자는 업무상 지득한 비밀에 관한 정보를 누설하거나 이를 인증심사 업무 이외의 목적에 사용하여서는 아니 된다.

② 인증심사 업무에 종사하는 자 또는 종사하였던 자는 인증에 관련하여 일체의 금전, 금품, 이익 등을 부당하게 수수하여서는 아니 된다.

제16조(업무 지침 등) 성능시험대행자는 인증 또는 심사업무 수행을 위해 필요한 경우 법령의 범위 내에서 인증 또는 심사업무에 관한 지침을 마련하여 시행할 수 있다.

제17조(재검토기한) 국토교통부장관은 「행정규제기본법」 및 「훈령·예규 등의 발령 및 관리에 관한 규정」에 따라 이 고시에 대하여 2026년 1월 1일을 기준으로 매 3년이 되는 시점(매 3년째의 12월 31일까지

를 말한다)마다 그 타당성을 검토하여 개선 등의 조치를 하여야 한다.

부 칙

이 고시는 발령한 날부터 시행한다.

[별표 1]

자동차 사이버보안 관리체계 인증기준(제6조 관련)

구분	항목	인증기준
1	적용 범위	자동차제작자등은 자동차 사이버보안 관리체계를 자동차의 개발·생산·생산 후 단계에 적용해야 한다.
2	사이버보안 관리 절차	자동차제작자등은 자동차 사이버보안을 관리하기 위한 절차를 수립해야 한다.
3	위험 식별 절차	자동차제작자등은 자동차 사이버보안 위험을 식별하기 위한 절차를 수립해야 한다.
4	위험 처리 절차	자동차제작자등은 식별된 자동차 사이버보안 위험을 평가하고 처리하기 위한 절차를 수립해야 한다.
5	위험 관리 검증 절차	자동차제작자등은 식별된 자동차 사이버보안 위험이 적절하게 관리되는지를 검증하기 위한 절차를 수립해야 한다.
6	시험 절차	자동차제작자등은 자동차 사이버보안을 시험하기 위한 절차를 수립해야 한다.
7	위험 평가 업데이트 절차	자동차제작자등은 자동차 사이버보안 위험 평가를 최신 상태로 유지하기 위한 업데이트 절차를 수립해야 한다.
8	모니터링 절차	자동차제작자등은 자동차 사이버공격·위협, 취약점을 모니터링하고 대응하기 위한 절차를 수립해야 한다.
9	데이터 수집 절차	자동차제작자등은 시도된 자동차 사이버공격·위협 관련 데이터를 수집하기 위한 절차를 수립해야 한다.
10	처리 기간	자동차제작자등은 식별된 사이버공격·위협 및 취약점을 적절한 기간 내에 완화하기 위한 처리 기간을 설정해야 한다.
11	모니터링 지속 수행	자동차제작자등은 자동차 사이버보안 모니터링을 지속적으로 수행함을 증명해야 한다.
12	공급망 관리	자동차제작자등은 자동차 사이버보안이 지속될 수 있도록 자동차의 부품 또는 서비스 등 자동차에 관련된 모든 요소의 공급망을 관리해야 한다.

[별표 2]

자동차 사이버보안 관리체계 인증번호 부여기준(제10조 관련)

자리 구분	1	2	3	4	5	6	7	8	9
부여기준	일련번호 ^(주1)				갱신 ^(주2)	연도 ^(주3)			

(주) 1. 일련번호는 발행 연도에서의 부여 순서를 의미한다.

2. 신규 : 0, 갱신 : 1

3. 인증발행 연도로 한다.

자동차 사이버공격·위협(제13조 관련)

1. 자동차와 관련된 백엔드 서버에 대한 사이버공격·위협

사이버공격·위협에 대한 분류		사이버공격·위협 또는 취약점의 예시	
1	백엔드 서버를 통해 자동차를 공격하거나 데이터를 추출 *백엔드 서버란 자동차에 서비스를 제공하기 위해 연산, 조회 등의 처리를 하는 제작사의 서버를 말함	1.1	내부 직원의 권한 남용(내부자 공격)
		1.2	백엔드 서버에 대한 무단 인터넷 접근 *백도어, 패치되지 않은 시스템 소프트웨어 취약점, SQL 공격 또는 기타 수단에 의해 활성화될 수 있음
		1.3	백엔드 서버에 대한 물리적인 무단 접근 *서버에 연결된 USB, 기타 매체 등으로 수행될 수 있음
2	백엔드 서버의 서비스를 중단시켜 자동차 작동에 영향	2.1	백엔드 서버에 대한 공격으로 인한 기능중단 *자동차와 상호작용하거나 자동차에서 요구하는 서비스를 제공하지 못하게 됨
3	백엔드 서버에 저장된 자동차 관련 데이터 손실 또는 손상	3.1	내부 직원의 권한 남용(내부자 공격)
		3.2	클라우드 정보 손실 *타 클라우드 서비스 공급업체에 데이터를 저장할 때, 중요한 데이터가 공격이나 사고로 인해 손실될 수 있음
		3.3	백엔드 서버에 대한 무단 인터넷 접근 *백도어, 패치되지 않은 시스템의 소프트웨어 취약점, SQL공격, 기타 수단에 의해 활성화될 수 있음
		3.4	백엔드 서버에 대한 물리적인 무단 접근 *서버에 연결된 USB, 기타 매체 등으로 수행될 수 있음
		3.5	의도하지 않은 데이터 공유로 인한 정보 침해(관리 오류 등)

2. 자동차 통신채널과 관련된 사이버공격·위협

사이버공격·위협에 대한 분류		사이버공격·위협 또는 취약점의 예시	
4	자동차가 수신하는 메시지 또는 데	4.1	위장 공격을 이용한 메시지 스푸핑

	이더를 스푸핑 *스푸핑이란 데이터 위·변조를 통해 합법적 사용자인 것처럼 위장하여 공격 대상을 속이는 공격 기술을 말함		*군집 주행 중 802.11p V2X, GNSS 메시지 등
		4.2	시빌 공격 *시빌 공격이란 도로에 자동차가 많은 것처럼 다른 자동차를 속이는 공격 기술을 말함
5	통신채널을 통해 자동차의 데이터 및 코드를 무단 조작, 삭제하거나 다른 공격을 위해 사용	5.1	통신채널에 코드 주입을 허용 *변조된 소프트웨어가 통신 스트림에 주입될 수 있음
		5.2	통신채널을 통한 자동차의 데이터/코드 조작을 허용
		5.3	통신채널을 통한 자동차의 데이터/코드 덮어쓰기를 허용
		5.4	통신채널을 통한 자동차의 데이터/코드 삭제를 허용
		5.5	통신채널을 통한 자동차의 데이터/코드 주입을 허용(데이터 코드 작성)
6	통신채널이 신뢰할 수 없는 메시지를 수신하거나, 가로채기 공격 또는 세션 하이재킹, 재전송 공격 *가로채기 공격이란 송·수신자 사이에 공격자가 끼어들어 데이터를 도청하거나 조작하는 공격 기술을 말함 *세션 하이재킹이란 공격자가 유효한 통신 세션(시스템 간 연결이 활성화된 상태) 등을 가로채어 접근하는 공격 기술을 말함	6.1	신뢰할 수 없는 출처의 정보를 수신
		6.2	가로채기 공격/세션 하이재킹
		6.3	재전송 공격 *통신 게이트웨이에 대한 공격을 통해 공격자가 ECU의 소프트웨어 또는 게이트웨이 펌웨어를 다운그레이드할 수 있음
7	통신 도청, 중요한 파일 또는 폴더에 대한 무단 접근 허용 등에 의한 정보 추출	7.1	정보 가로채기/방해 전파/통신 모니터링
		7.2	파일 또는 데이터에 대한 무단 접근 권한 획득
8	통신채널을 통한 서비스 거부 공격으로 자동차 기능 방해	8.1	서비스 거부 공격 *서비스 거부 공격이란 많은 수의 공격 데이터를 자동차로 전송하여 정상적으로 서비스를 제공할 수 없도록 하는 공격 기술을 말함
		8.2	블랙홀 공격

			*블랙홀 공격이란 자동차 간 통신을 교란하기 위하여 자동차 간의 메시지를 차단하는 공격 기술을 말함
9	권한이 없는 사용자가 자동차 시스템에 대한 접근 권한 획득	9.1	권한이 없는 사용자가 자동차 시스템에 대한 관리자 권한을 탈취
10	통신 매체에 내장된 바이러스를 통한 자동차 시스템 감염	10.1	통신 매체에 내장된 바이러스가 자동차 시스템을 감염
11	자동차가 수신하는 메시지에 악성 콘텐츠가 포함	11.1	악성 내부(CAN 등) 메시지
		11.2	악성 V2X 메시지 *I2V 메시지(RSA 등) 또는 V2V 메시지(BSM 등)
		11.3	악성 진단 메시지
		11.4	악성 전용 메시지 *OEM 또는 관련 부품사들이 정의하여 사용하는 고유 메시지

3. 업데이트 절차와 관련된 사이버공격 · 위협

사이버공격 · 위협에 대한 분류		사이버공격 · 위협 또는 취약점의 예시	
12	업데이트 절차와 관련된 오용 또는 공격	12.1	무선 소프트웨어 업데이트(OTA) 절차와 관련된 공격 *조작된 시스템 업데이트 프로그램 또는 펌웨어가 포함됨
		12.2	OBD 등 진단 인터페이스, USB 등 유선으로 실시하는 소프트웨어 업데이트 절차와 관련된 공격 *조작된 시스템 업데이트 프로그램 또는 펌웨어가 포함됨
		12.3	업데이트 절차와 관련된 공격은 아니지만, 소프트웨어가 이미 조작됨
		12.4	소프트웨어 공급자의 암호키가 훼손되어 잘못된 업데이트를 실행
13	정상적인 업데이트 거부	13.1	업데이트 서버 또는 네트워크의 서비스 거부 공격을 통해 중요 소프트웨어

		업데이트 배포 및 특정 기능의 활성화 등을 방해
--	--	----------------------------

4. 의도하지 않은 행동으로 인한 사이버공격·위협

사이버공격·위협에 대한 분류		사이버공격·위협 또는 취약점의 예시	
15	자동차 소유자, 운영자 또는 유지 보수 엔지니어 등(이하 “합법적 사용자”라 한다)이 의도치 않게 사이버공격을 용이하게 행동	15.1	합법적 사용자가 속임을 당하여 의도하지 않게 악성 프로그램을 실행하거나 사이버공격을 허용
		15.2	자동차 사이버보안 확보를 위해 내부에 규정된 보안 절차를 따르지 않음

5. 자동차의 외부 연결에 대한 사이버공격·위협

사이버공격·위협에 대한 분류		사이버공격·위협 또는 취약점의 예시	
16	텔레매틱스, 원격 시스템, 근거리 무선 통신 시스템 등의 자동차의 외부 연결 관련 기능을 조작하여 사이버공격을 가능하게 함	16.1	원격 잠금장치, 이모빌라이저 등 원격으로 작동하도록 설계된 시스템의 기능을 조작
		16.2	차량 텔레매틱스 조작 *민감한 제품의 온도 측정 조작, 원격으로 차 문 잠금 해제
		16.3	근거리 무선 시스템 또는 센서와의 간섭
17	엔터테인먼트, 애플리케이션 등의 제삼자 소프트웨어에 의한 공격	17.1	손상되거나 소프트웨어 보안이 취약한 애플리케이션을 이용하여 자동차 시스템을 공격
18	외부 인터페이스(USB, OBD 등)에 연결된 장치를 통한 자동차 시스템 공격	18.1	외부 인터페이스를 통해 공격
		18.2	바이러스에 감염된 매체가 자동차 시스템에 연결
		18.3	OBD 등 진단 인터페이스를 통해 사이버공격을 용이하게 함 *직·간접적인 자동차 매개 변수 조작 등

6. 자동차 데이터/코드에 대한 사이버공격·위협

사이버공격·위협에 대한 분류		사이버공격·위협 또는 취약점의 예시	
19	자동차 데이터/코드 추출	19.1	자동차 시스템에서 저작권이 있거나 독점하고 있는 소프트웨어 추출(제품 불법 복제)

		19.2	소유자의 개인 정보에 대한 무단 접근 *개인 신상정보, 결제 계좌 정보, 주소록 정보, 위치 정보, 자동차 전자 ID 등
		19.3	암호키 추출
20	자동차 데이터/코드 조작	20.1	자동차 전자 ID에 대한 불법/무단 변경
		20.2	신원 조작 *요금징수 시스템과 통신 시 다른 ID 사용 등
		20.3	모니터링 시스템을 우회하는 작업 *ODR 추적기 데이터, 실행 횟수 등 메시지 해킹/수정/차단
		20.4	자동차 주행데이터를 변조하기 위한 데이터 조작 *주행거리, 주행 속도, 주행 방향 등
		20.5	시스템 진단 데이터에 대한 무단 변경
21	데이터/코드 삭제	21.1	시스템 이벤트 로그 무단 삭제/조작
22	멀웨어 유입	22.2	악의적으로 소프트웨어를 조작
23	새로운 소프트웨어 설치 또는 기존 소프트웨어에 덮어쓰기	23.1	자동차 제어 시스템 또는 정보시스템의 소프트웨어가 위조
24	시스템 또는 운영의 중단	24.1	서비스 거부 *CAN 버스를 플러딩하거나 메시지 전송률을 높여 ECU의 고장을 유발하여 내부 네트워크에서 통신 중단 유발
25	자동차 매개변수 조작	25.1	무단 접근을 통해 자동차 주요 기능의 구성 매개변수를 변조 *브레이크 데이터, 에어백 전개 임계값 등
		25.2	무단 접근을 통해 충전 기능과 관련된 전압, 전력, 배터리 온도 등과 같은 매개변수를 변조

7. 악용될 수 있는 잠재적 취약점

취약점에 대한 분류		사이버공격·위협 또는 취약점의 예시	
26	암호 기술이 손상되거나 제대로 적용되지 않음	26.1	암호키의 길이가 짧고 암호의 변경 주기가 긴 암호 알고리즘을 사용
		26.2	중요한 시스템을 보호하기 위한 암호

			알고리즘을 적절히 사용하지 않음
		26.3	이미 사용 중지되었거나 곧 중단될 암호 알고리즘 사용
27	부품이나 소모품 등이 손상되어 자동차가 공격받음	27.1	사이버공격에 대응하기 위한 설계 기준을 충족하지 못하는 하드웨어 또는 소프트웨어 사용
28	소프트웨어 또는 하드웨어 개발 과정에서의 취약점	28.1	소프트웨어 버그 *소프트웨어 버그의 존재는 잠재적으로 공격 가능한 취약점이 될 수 있으며, 알려진 불량 코드/버그의 존재 여부 확인을 위한 테스트 혹은 알 수 없는 불량 코드/버그의 존재 위험을 줄이기 위한 테스트를 하지 않는 경우 발생할 수 있음
		28.2	개발용 인터페이스 등을 사용하여 공격자가 ECU에 접근하거나 상위 권한을 획득 *디버그 포트, JTAG 포트, 마이크로프로세서, 개발 인증서, 개발자 암호 등
29	네트워크 설계로 인한 취약점	29.1	불필요한 인터넷 포트가 열려있어 네트워크 시스템에 대한 접근 허용
		29.2	네트워크 망분리를 우회하여 제어권 확보 *보호망을 우회하여 다른 네트워크 세그먼트에 대한 접근 권한을 획득하여, 임의의 CAN 메시지 전송과 같은 악의적인 행위를 수행하기 위하여 보호되지 않은 게이트웨이 또는 접근 지점을 공격 *특장 자동차(트럭 트레일러 게이트웨이 등)를 사용하는 경우를 예로 들 수 있음
31	의도하지 않은 데이터 전송	31.1	정보 침해 *렌터카로 사용·판매되는 등 자동차 사용자가 바뀌면서 개인 정보가 누출될 수 있음
32	물리적 조작으로 인한 시스템 공격 가능성	32.1	하드웨어 조작 *메세지 가로채기 공격 등을 위해 승인된 하드웨어(센서 등)를 승인되지 않은 하드웨어로 교체하거나, 자석을 사용하여 기어박스에 연결된 홀 효과 센서를 조작하는 방식 등으로 센서가 수집한 정보를 조작

※ 비고 : 위 표는 개정 당시 “UN Regulation No. 155, Annex 5의 Part A. Vulnerability or attack method related to the threats”를 참조하였음.

자동차 사이버공격·위협에 대한 보안 조치(제14조 관련)

1. 자동차 통신채널과 관련된 위협에 대한 보안 조치

사이버공격·위협 또는 취약점의 예시		보안 조치	
4.1	위장 공격을 이용한 메시지 스푸핑 *군집 주행 중 802.11p V2X, GNSS 메시지 등	M10	자동차는 수신하는 메시지의 신뢰성 및 무결성을 확인해야 함
4.2	시빌 공격 *시빌 공격이란 도로에 자동차가 많은 것처럼 다른 자동차를 속이는 공격 기술을 말함	M11	암호키를 저장하기 위한 보안 조치가 구현되어야 함 *하드웨어 보안 모듈(HSM) 사용
5.1	통신채널에 코드 주입을 허용 *변조된 소프트웨어가 통신 스트림에 주입될 수 있음	M10	자동차는 수신하는 메시지의 신뢰성 및 무결성을 확인해야 함
		M6	시스템은 위협을 최소화하기 위해 설계 단계부터 보안 조치를 고려해야 함
5.2	통신채널을 통한 자동차의 데이터/코드 조작을 허용	M7	자동차의 데이터/코드를 보호하기 위해 접근 통제 기술 및 설계가 적용되어야 함
5.3	통신채널을 통한 자동차의 데이터/코드 덮어쓰기를 허용		
5.4 & 21.1	통신채널을 통한 자동차의 데이터/코드 삭제를 허용		
5.5	통신채널을 통한 자동차의 데이터/코드 주입을 허용(데이터 코드 작성)		
6.1	신뢰할 수 없는 출처의 정보를 수신	M10	자동차는 수신하는 메시지의 신뢰성 및 무결성을 확인해야 함
6.2	가로채기 공격/세션 하이재킹 *가로채기 공격이란 송·수신자 사이에 공격자가 끼어들어 데이터를 도청하거나 조작하는 공격 기술을 말함 *세션 하이재킹이란 공격자가 유효한 통신 세션(시스템 간 연결이 활성화된 상태) 등을 가로채어 접근하는 공격 기술을 말함		
6.3	재전송 공격 *통신 게이트웨이에 대한 공격을 통해 공격자가 ECU의 소프트웨어 또는 게이트웨이 펌웨어를 다운그레이드할 수 있음		

7.1	정보 가로채기/방해 전파/통신 모니터링	M12	자동차와 주고받는 기밀 정보는 보호되어야 함
7.2	파일 또는 데이터에 대한 무단 접근 권한 획득	M8	시스템 설계 및 접근 제어를 통해 권한이 없는 사용자가 개인 또는 시스템의 중요 데이터에 접근할 수 없어야 함 *보안 조치의 예는 OWASP(the Open Web Application Security Project)에서 찾을 수 있음
8.1	서비스 거부 공격 *많은 수의 공격 데이터를 자동차로 전송하여 정상적으로 서비스를 제공할 수 없음	M13	서비스 거부 공격을 감지하고 복구 조치를 취해야 함
8.2	블랙홀 공격 *자동차 간 통신을 교란하기 위하여 자동차 간의 메시지를 차단할 수 있음		
9.1	권한이 없는 사용자가 자동차 시스템에 대한 관리자 권한을 탈취	M9	무단 접근을 방지하고 탐지하는 대책을 취해야 함
10.1	통신 매체에 내장된 바이러스가 자동차 시스템을 감염	M14	내장된 멀웨어로부터 시스템을 보호하기 위한 조치를 고려해야 함
11.1	악성 내부(CAN 등) 메시지	M15	악성 내부 메시지나 활동을 탐지하는 조치를 고려해야 함
11.2	악성 V2X 메시지 *I2V 메시지(RSA 등) 또는 V2V 메시지(BSM 등)	M10	자동차는 수신하는 메시지의 신뢰성 및 무결성을 확인해야 함
11.3	악성 진단 메시지		
11.4	악성 전용 메시지 *OEM 또는 관련 부품사들이 정의하여 사용하는 고유 메시지		

2. 업데이트 절차와 관련된 위협에 대한 보안 조치

사이버공격 · 위협 또는 취약점의 예시		보안 조치	
12.1	무선 소프트웨어 업데이트(OTA) 절차와 관련된 공격 *조작된 시스템 업데이트 프로그램 또는 펌웨어가 포함됨	M16	소프트웨어 업데이트가 안전하게 실행되어야 함
12.2	OBD 등 진단 인터페이스, USB 등 유선으로 실시하는 소프트웨어 업데이트 절차		

	차와 관련된 공격 *조작된 시스템 업데이트 프로그램 또는 펌웨어가 포함됨		
12.3	업데이트 절차와 관련된 공격은 아니지만, 소프트웨어가 이미 조작됨		
12.4	소프트웨어 공급자의 암호키가 훼손되어 잘못된 업데이트를 실행	M11	암호키를 저장하기 위한 보안 조치가 구현되어야 함 *하드웨어 보안 모듈(HSM) 사용
13.1	업데이트 서버 또는 네트워크의 서비스 거부 공격을 통해 중요 소프트웨어 업데이트 배포 및 특정 기능의 활성화 등을 방해	M3	백엔드 서버가 서비스 제공에 중요한 경우 중단에 대비한 복구 대책 등의 보안 조치가 적용되어야 함. *보안 조치의 예는 OWASP에서 찾을 수 있음

3. 의도하지 않은 행동으로 인한 위협에 대한 보안 조치

사이버공격 · 위협 또는 취약점의 예시		보안 조치	
15.1	합법적 사용자가 속임을 당하여 의도하지 않게 악성 프로그램을 실행하거나 사이버공격을 허용	M18	최소 권한 원칙에 따라 사용자별 접근 권한을 정의하고, 정의된 접근 권한대로 제어해야 함
15.2	자동차 사이버보안 확보를 위해 내부에 규정된 보안 절차를 따르지 않음	M19	보안 기능 관리와 관련된 작업 및 접근 기록을 포함한 보안 절차를 정의하고 준수해야 함

4. 자동차의 외부 연결과 관련된 위협에 대한 보안 조치

사이버공격 · 위협 또는 취약점의 예시		보안 조치	
16.1	원격 잠금장치, 이모빌라이저 등 원격으로 작동하도록 설계된 시스템의 기능을 조작	M20	원격 접근이 가능한 시스템에 보안 조치가 적용되어야 함
16.2	차량 텔레매틱스 조작 *민감한 제품의 온도 측정 조작, 원격으로 차문 잠금 해제		
16.3	근거리 무선 시스템 또는 센서와의 간섭		
17.1	손상되거나 소프트웨어 보안이 취약한 애플리케이션을 이용하여 자동차 시스템을 공격	M21	소프트웨어의 보안과 관련된 사항들이 평가되어야 하고, 인증 및 무결성이 보호되어야 함

			며, 제삼자 소프트웨어로부터의 위험을 최소화하기 위한 보안 조치가 적용되어야 함
18.1	외부 인터페이스를 통해 공격	M22	외부 인터페이스에 보안 조치가 적용되어야 함
18.2	바이러스에 감염된 매체가 자동차 시스템에 연결		
18.3	OBD 등 진단 인터페이스를 통해 사이버 공격을 용이하게 함 *직·간접적인 자동차 매개 변수 조작 등		

5. 자동차 데이터/코드와 관련된 위협에 대한 보안 조치

사이버공격·위협 또는 취약점의 예시		보안 조치	
19.1	자동차 시스템에서 저작권이 있거나 독점하고 있는 소프트웨어 추출(제품 불법 복제)	M7	시스템 데이터/코드를 보호하기 위해 접근 통제 기술 및 설계가 적용되어야 함 *보안 조치의 예는 OWASP에서 참조 가능
19.2	소유자의 개인 정보에 대한 무단 접근 *개인 신상정보, 결제 계좌 정보, 주소록 정보, 위치 정보, 자동차 전자 ID 등	M8	시스템 설계 및 접근 제어를 통해 권한이 없는 사용자가 개인 또는 시스템의 중요 데이터에 접근할 수 없어야 함 *보안 조치의 예는 OWASP에서 참조 가능
19.3	암호키 추출	M11	암호키를 저장하기 위한 보안 조치가 구현되어야 함 *하드웨어 보안 모듈(HSM) 사용
20.1	자동차 전자 ID에 대한 불법/무단 변경	M7	시스템 데이터/코드를 보호하기 위해 접근 통제 기술 및 설계가 적용되어야 함 *보안 조치의 예는 OWASP에서 참조 가능
20.2	신원 조작 *요금징수 시스템과 통신 시 다른 ID 사용 등		
20.3	모니터링 시스템을 우회하는 작업 *ODR 추적기 데이터, 실행 횟수 등 메시지 해킹	M7	시스템 데이터/코드를 보호하기 위해 접근 통제 기술 및 설

	/수정/차단		계가 적용되어야 함
20.4	자동차 주행데이터를 변조하기 위한 데이터 조작 *주행거리, 주행 속도, 주행 방향 등		*보안 조치의 예는 OWASP에서 참조 가능
20.5	시스템 진단 데이터에 대한 무단 변경		*센서 또는 전송된 데이터에 대한 데이터 조작 공격은 서로 다른 정보 소스의 데이터를 연관시키는 방법으로 보안 조치 가능
21.1	시스템 이벤트 로그 무단 삭제/조작	M7	시스템 데이터/코드를 보호하기 위해 접근 통제 기술 및 설계가 적용되어야 함 *보안 조치의 예는 OWASP에서 참조 가능
22.2	악의적으로 소프트웨어를 조작		
23.1	자동차 제어 시스템 또는 정보시스템의 소프트웨어가 위조		
24.1	서비스 거부 *CAN 버스를 플러딩하거나 메시지 전송률을 높여 ECU의 고장을 유발하여 내부 네트워크에서 통신 중단 유발	M13	서비스 거부 공격을 감지하고, 복구 조치를 취해야 함
25.1	무단 접근을 통해 자동차 주요 기능의 구성 매개변수를 변조 *브레이크 데이터, 에어백 전개 임계값 등	M7	시스템 데이터/코드를 보호하기 위해 접근 통제 기술 및 설계가 적용되어야 함 *보안 조치의 예는 OWASP에서 참조 가능
25.2	무단 접근을 통해 충전 기능과 관련된 전압, 전력, 배터리 온도 등과 같은 매개변수를 변조		

6. 악용될 수 있는 잠재적 취약점에 대한 보안 조치

사이버공격·위협 또는 취약점의 예시		보안 조치	
26.1	암호키의 길이가 짧고 암호의 변경 주기가 긴 암호 알고리즘을 사용	M23	소프트웨어 및 하드웨어 개발 시 사이버보안 모범사례를 따라야 함
26.2	중요한 시스템을 보호하기 위한 암호 알고리즘을 적절히 사용하지 않음		
26.3	이미 사용 중지되었거나 곧 중단될 암호 알고리즘 사용		
27.1	사이버공격에 대응하기 위한 설계 기준을 충족하지 못하는 하드웨어 또는 소프트웨어 사용		

28.1	소프트웨어 버그 *소프트웨어 버그의 존재는 잠재적으로 공격 가능한 취약점이 될 수 있으며, 알려진 불량 코드/버그의 존재 여부 확인을 위한 테스트 혹은 알 수 없는 불량 코드/버그의 존재 위험을 줄이기 위한 테스트를 하지 않는 경우 발생할 수 있음	M23	소프트웨어 및 하드웨어 개발 시 사이버보안 모범사례를 따라야 함 *적절한 범위의 사이버보안 테스트 포함
28.2	개발용 인터페이스 등을 사용하여 공격자가 ECU에 접근하거나 상위 권한을 획득 *디버그 포트, JTAG 포트, 마이크로프로세서, 개발 인증서, 개발자 암호 등		
29.1	불필요한 인터넷 포트가 열려있어 네트워크 시스템에 대한 접근 허용		
29.2	네트워크 망분리를 우회하여 제어권 확보 *보호망을 우회하여 다른 네트워크 세그먼트에 대한 접근 권한을 획득하여, 임의의 CAN 메시지 전송과 같은 악의적인 행위를 수행하기 위하여 보호되지 않은 게이트웨이 또는 접근 지점을 공격 *특장 자동차(트럭 트레일러 게이트웨이 등)를 사용하는 경우를 예로 들 수 있음	M23	소프트웨어 및 하드웨어 개발 시 사이버보안 모범사례를 따라야 함

7. 차량 데이터 손실 및 데이터 유출과 관련된 위협에 대한 보안 조치

사이버공격 · 위협 또는 취약점의 예시		보안 조치	
31.1	정보 침해 *렌터카로 사용·판매되는 등 자동차 사용자가 바뀌면서 개인정보가 유출될 수 있음	M24	개인정보의 보관은 데이터 무결성 및 기밀성 보호를 위한 모범사례를 따라야 함

8. 시스템의 물리적 조작과 관련된 위협에 대한 보안 조치

사이버공격 · 위협 또는 취약점의 예시		보안 조치	
32.1	하드웨어 조작 *메세지 가로채기 공격 등을 위해 승인된 하드웨어(센서 등)를 승인되지 않은 하드웨어로 교체하거나, 자석을 사용하여 기어박스에 연결된 홀 효과 센서를 조작하는 방식 등으로 센서가 수집한 정보를 조작	M9	무단 접근을 방지 및 감지할 수 있는 대책을 취해야 함

9. 자동차와 관련된 백엔드 서버의 위협에 대한 보안 조치

사이버공격 · 위협 또는 취약점의 예시		보안 조치	
1.1 &	내부 직원의 권한 남용(내부자 공격)	M1	내부자 공격 위험을 최소화하

3.1			기 위해 백엔드 서버에 보안 조치가 적용되어야 함
1.2 & 3.3	백엔드 서버에 대한 무단 인터넷 접근 *백도어, 패치되지 않은 시스템 소프트웨어 취약점, SQL 공격 또는 기타 수단에 의해 활성화될 수 있음	M2	무단 접근을 최소화하기 위해 백엔드 서버에 보안 조치가 적용되어야 함
1.3 & 3.4	백엔드 서버에 대한 물리적인 무단 접근 *서버에 연결된 USB, 기타 매체 등으로 수행될 수 있음	M8	시스템 설계 및 접근 제어를 통해 권한이 없는 사용자가 개인 또는 시스템의 중요 데이터에 접근할 수 없어야 함 *보안 조치의 예는 OWASP에서 참조 가능
2.1	백엔드 서버에 대한 공격으로 인한 기능 중단 *자동차와 상호작용하거나 자동차에서 요구하는 서비스를 제공하지 못하게 됨	M3	백엔드 서버가 서비스 제공에 중요한 경우 중단에 대비한 복구 대책 등의 보안 조치가 적용되어 있어야 함. *보안 조치의 예는 OWASP에서 찾을 수 있음
3.2	클라우드 정보 손실 *타 클라우드 서비스 공급업체에 데이터를 저장할 때, 중요한 데이터가 공격이나 사고로 인해 손실될 수 있음	M4	클라우드 컴퓨팅과 관련된 위험을 최소화하기 위한 보안 조치가 적용되어야 함 *보안 조치의 예는 OWASP 및 NCSC에서 참조 가능
3.5	의도하지 않은 데이터 공유로 인한 정보 침해(관리 오류 등)	M5	데이터 유출을 방지하기 위한 보안 통제가 백엔드 서버에 적용되어야 함 *보안 조치의 예는 OWASP에서 참조 가능

10. 데이터의 물리적 손실에 대한 보안 조치

사이버공격 · 위협 또는 취약점의 예시		보안 조치	
30.1	제삼자에 의한 피해, 교통사고, 도난 등 물리적인 손상으로 민감 데이터가 손실되거나 손상	M24	개인정보의 보관은 데이터 무결성 및 기밀성 보호를 위한 모범사례를 따라야 함 *보안 조치의 예는 ISO/SC27/WG5에서 참조 가능
30.2	DRM(디지털 권한 관리) 충돌 등으로 사용자 데이터가 손실되거나 손상		

30.3	IT 컴포넌트의 손상으로 민감 데이터의 무결성이 훼손되어 연쇄적인 문제가 발 생 *키 변경의 경우		
------	---	--	--

※ 비고 : 위 표는 개정 당시 “UN Regulation No. 155, Annex 5의 Part B. Mitigations to the threats intended for vehicles” 및 “Part C. Mitigations to the threats outside of vehicles”를 참조하였음.

인증서 변경 신고서

접수번호	접수일시	처리기간	15일
------	------	------	-----

신청인	제작자등의 명칭	제작자등록번호
	대표자명	전화번호
	주소	
	전자우편(e-mail)	

인증정보	최초제작자명 (수입자만 해당합니다)	
	인증번호	
	인증범위	

변경 내용	변경전	
	변경후	

변경사유	
------	--

「자동차관리법」 제30조의9제2항 후단에 따라 위와 같이 변경을 신고합니다.

년 월 일

신청인(대표자)

(서명 또는 인)

국토교통부장관(성능시험대행자) 귀하

첨부서류	변경내용을 증명하는 서류
------	---------------

210mm×297mm[(백상지(80g/㎡)또는 중질지(80g/㎡)]

이의신청서

접수번호	접수일시	처리기간	30일
신청인	제작자등의 명칭		제작자등록번호
	대표자명		전화번호
	주소		
	전자우편(e-mail)		
통지사항	통지를 받은 날		
	통지된 사항		
이의신청 대상			
이의신청 사유			

「자동차 사이버보안 관리체계 인증 등에 관한 고시」 제9조제1항에 따라 위와 같이 이의 신청합니다.

년 월 일

신청인(대표자)

(서명 또는 인)

국토교통부장관(성능시험대행자) 귀하

첨부서류	이의신청 내용을 확인할 수 있는 증빙 자료(필요시)
------	------------------------------

210mm×297mm[(백상지(80g/㎡)또는 중질지(80g/㎡)]

인증서 재발급 신청서

접수번호	접수일시	처리기간	15일
신청인	제작자등의 명칭	제작자등록번호	
	대표자명	전화번호	
	주소		
	전자우편(e-mail)		
인증 정보	인증번호		
	인증범위		
재발급 사유			

「자동차 사이버보안 관리체계 인증 등에 관한 고시」 제10조제4항에 따라 위와 같이 인증서의 재발급을 신청합니다.

년 월 일

신청인(대표자)

(서명 또는 인)

국토교통부장관(성능시험대행자) 귀하

210mm×297mm[(백상지(80g/㎡)또는 중질지(80g/㎡)]